

CYBERSECURITY INCIDENT REPORT

HIGH SEVERITY

Entry #001

Hotel La Rambla

PHISHING & ACCOUNT TAKEOVER · SEPTEMBER 2, 2025

AUTHOR	ENTRY	ROLE	DATE	INDUSTRY	ORGANIZATION	INCIDENT TYPE
Edvin Johannes Piirsalu	#001	Security Analyst	September 2, 2025	Hospitality	Hotel La Rambla	Phishing & Account Takeover (ATO)

1. Executive Summary

A phishing attack targeted employees of Hotel La Rambla, resulting in unauthorized access to the hotel's account on the Expedia Group partner extranet platform.

The attacker used a combination of phishing and social engineering to obtain a password reset authorization code from hotel staff. After gaining access, the threat actor canceled guest reservations and attempted to redirect guests to fraudulent payment links.

The incident was detected within 15 minutes after guests reported unexpected reservation cancellations. Rapid escalation and coordination with Expedia support allowed the hotel to contain the attack within approximately 25 minutes, preventing financial loss to guests.

2. Incident Overview

Category	Value
Incident Type	Phishing + Account Takeover
Severity	High
Affected System	Expedia Partner Extranet Account
Data Breach	No confirmed data exfiltration
Financial Impact	No confirmed financial loss
Detection Method	Guest reports and internal investigation

3. Attack Scenario

The attack involved two stages.

Stage 1 — Phishing

A phishing message instructed hotel staff to reset their Expedia extranet password through a fraudulent website.

hxxps://expedia-partners-reset[.]com

Stage 2 — Social Engineering

The attacker called the hotel pretending to be technical support and requested the password reset authorization code. A staff member unknowingly disclosed the code, allowing the attacker to take control of the account.

4. The 5 W's

Who	An unidentified threat actor conducted a phishing and social engineering attack targeting hotel staff.
What	A phishing attack followed by account takeover (ATO) of the hotel's Expedia partner account. The attacker canceled guest reservations and attempted to collect fraudulent payments from guests.
Where	The incident affected the hotel's account on the Expedia partner platform associated with Hotel La Rambla.
When	Tuesday, approximately 09:00 a.m. The incident was detected roughly 15 minutes after the account takeover.
Why	The attacker's motivation appears to be financial gain by tricking guests into sending payments through fraudulent links after their reservations were canceled.

5. Indicators of Compromise (IOCs)

Type	Indicator	Description
Phishing URL	hxxps://expedia-partners-reset[.]com	Fake password reset website
Phone Number	Unknown external number	Used by attacker posing as support
Email Subject	"Urgent: Expedia password reset required"	Phishing email sent to hotel staff
Compromised Account	Expedia Partner Account	Account accessed after password reset

6. Incident Timeline

08:55	Hotel staff received a phishing message requesting a password change for the Expedia extranet account
09:00	Staff clicked the phishing link and initiated a password reset
09:02	Threat actor called the hotel pretending to be support and requested the password reset authorization code
09:03	Staff member provided the code, enabling the attacker to take control of the Expedia account
09:05	Attacker began canceling reservations and sending fraudulent payment requests to guests

09:15	Guests began calling the hotel to report unexpected reservation cancellations and suspicious payment requests
09:16	Hotel staff recognized suspicious activity and escalated internally
09:20	Hotel contacted Expedia support and requested immediate intervention
09:25	Expedia temporarily suspended activity on the hotel's account to prevent further abuse

7. Impact Assessment

Operational Impact

- Several guest reservations were canceled by the attacker
- Hotel operations were disrupted due to incoming guest inquiries and complaints

Financial Impact

- No confirmed monetary loss by guests
- No direct financial loss to the hotel

Reputational Impact

- Some guests canceled reservations due to reduced trust
- Temporary damage to hotel reputation and guest confidence

8. Containment Actions

- Hotel staff immediately reported the incident to Expedia Group
- Expedia temporarily suspended all account activity
- Passwords were reset and account control was restored
- Staff communicated with affected guests to clarify the situation and confirm that fraudulent payment requests should be ignored

9. Security Control Analysis

Controls That Failed

- Lack of staff awareness regarding phishing and social engineering attacks
- Absence of multi-factor authentication (MFA) on the Expedia partner account
- No internal policy preventing the sharing of verification codes via phone

Controls That Helped Contain the Attack

- Rapid detection through guest reports
- Fast internal escalation by hotel staff
- Immediate response from Expedia support team

10. Root Cause

The incident occurred due to a successful phishing attack combined with social engineering. The attacker exploited human error by convincing a staff member to disclose the password reset authorization code over the phone.

This allowed the attacker to reset the account password and gain full access to the Expedia partner account.

11. Post-Incident Actions

- Reset all affected account credentials
- Enable MFA where available for external booking platforms
- Conduct internal staff awareness training on phishing threats
- Review and update hotel cybersecurity policies regarding account security and verification procedures
- Notify all affected guests about the security incident and the attempted fraud. Communication was provided promptly in accordance with the notification obligations established under the General Data Protection Regulation and applicable Spanish data protection regulations

12. Key Lessons Learned

Phishing + Social Engineering	Can bypass technical controls — human awareness is the critical last line of defense.
Staff Training	Critical in preventing credential compromise and recognizing social engineering tactics.
Multi-Factor Authentication	Significantly reduces the risk of account takeover even when credentials are compromised.
Rapid Detection & Response	Can prevent financial losses — the 25-minute containment window prevented all confirmed monetary damage.

13. Incident Outcome

The incident was successfully contained. No financial losses occurred and malicious activity was stopped quickly through coordinated response actions. Additional preventive security controls are being implemented to reduce the likelihood of similar attacks in the future.